

引起美国身份认证标准 NIST SP800-63-2 的修改

2016 年 8 月，申请人下述代表性论文在网络公开，10 月正式发表于信息安全顶级会议 ACM CCS: Ding Wang, Zijian Zhang, Ping Wang, Jeff Yan, Xinyi Huang. Targeted Online Password Guessing: An Underestimated Threat. Proc. of the 23rd ACM Conference on Computer and Communications Security (ACM CCS 2016), pp. 1242–1254. Oct 24, 2016 - Oct 28, 2016, Vienna, Austria.

该论文基于大规模真实的数据测试结果显示，在允许猜测 100 次的情况下，如果仅知道目标用户的一些常见个人信息，攻击者的猜测成功率可达 20%；如果知道用户在其它网站曾经泄露的一个口令，成功率可达 77%。这一结果大大超出了此前人们的预期，被福布斯、每日邮报、每日科学、Communications of the ACM、Naked Security 等 261 国际媒体报道或转载（详见：

<http://www.forbes.com/sites/leemathews/2016/11/10/100-guesses-is-enough-to-crack-your-password/#1f7e61c7e981>

<http://www.dailymail.co.uk/sciencetech/article-3907088/The-secret-password-using-Password-Researchers-warn-internet-users-making-easy-hackers-access-accounts.html>

<https://www.sciencedaily.com/releases/2016/11/161107112626.htm>

<http://cacm.acm.org/news/209702-online-password-guessing-threat-underestimated/fulltext>

<https://nakedsecurity.sophos.com/2016/11/09/would-your-password-withstand-100-guesses-from-a-hacker/>

该论文引起了美国国家技术标准局（NIST）的关注。NIST 在 2013 年 8 月发布的美国国家身份认证标准 NIST SP800-63-2（<https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-63-2.pdf>）中，攻击者被允许在线猜测 100 次，并且认为口令在线猜测非常容易防御。在 2017 年 6 月新发布的标准 NIST SP800-63-3（<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-3.pdf>）中，去除了旧版本 NIST SP800-63-2 中允许攻击者在线猜测 100 次的表述（“Attacker can make on the subscriber’s account to 100 or fewer in any 30-day period”）。

Re: [usnistgov/800-63-3] The online password guessing threat is largel...

精简信息

发起会议

发件人：Jim Fenton <notifications@github.com>

(由 noreply@github.com 代发)

时间：2016年09月17日 02:48:03 (星期六)

收件人：usnistgov/800-63-3 <800-63-3@noreply.github.com>

抄送：Ding Wang <wangdingg@pku.edu.cn> Author <author@noreply.github.com>

The wording in the appendix is being changed as you suggested. Please also consider the recommendations in SP 800-63B section 5.2.2. While these are primarily focused on preventing subscribers from being inadvertently locked out from their accounts, they also provide some further protection against sibling passwords from other accounts.

If you have further suggestions on avoiding these attacks that you think should be included, please suggest them.

Thank you for the link to your forthcoming paper. Please note that the wording it cites at the end of section 5.2 will not be in the document once the change is merged.

You are receiving this because you authored the thread.

Reply to this email directly, [view it on GitHub](#), or [mute the thread](#).

图 1 NIST 工作人员通过邮件征询申请人及合作者的防御建议

NIST 工作人员进一步就如何防御口令在线猜测威胁，通过邮件（如图 1）征询申请人及合作者的建议：“The wording in the appendix is being changed as you suggested. Please also consider the recommendations in SP 800-63B section 5.2.2. While these are primarily focused on preventing subscribers from being inadvertently locked out from their accounts, they also provide some further protection against sibling passwords from other accounts. If you have further suggestions on avoiding these attacks that you think should be included, please suggest them.”

最终，NIST SP-800-63-3 新版标准在节“5.2.2 Rate Limiting (Throttling)”新增了 4 条针对定向在线口令猜测攻击的防御措施，详见 <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-3.pdf>

“申请人代表性论文引起 NIST SP800-63-2 修改”这一事件，得到多位美国学者（在他们公开发表的重要会议论文中）的佐证和肯定。2018 年，俄亥俄州立大学的五位学者在论文【Proc. ACSAC’18, pp.89-100, <https://doi.org/10.1145/3274694.3274714>】中，明确指出申请人的前述 ACM CCS 2016 论文，即下文中的“Wang et al. [43]”引起了 NIST 标准的修改：

“Particularly, Wang et al. [43] have very recently developed efficient guessing algorithms for targeted online password attacks with the help of auxiliary information of the targeted accounts. The results were astonishing: Within 100 guesses, the algorithms could successfully crack 73% of the normal users’ accounts and 32% of the security-savvy users’ accounts (when evaluated against leaked password databases). These results have challenged NIST’s Digital Authentication Guideline [17] which suggested that “Online attacks where the attacker attempts to log in by guessing the password can be readily addressed by throttling the rate of login attempts permitted.” This remark has been hence removed from the document after the publication of [43].”

2017 年，ACM Fellow、暗网 Tor 发明人、美国海军研究实验室 Paul Syverson 研究组在论文【HotPET 2017, <https://petsymposium.org/2017/papers/hotpets/oft-target-1707.pdf>】中，把申请人 CCS 2016 论文，即下文中的“[10]”作为定向攻击的典型代表，并指出申请人的工作迅速引起了美国身份认证标准的修订：

“Most research on security for widely-used systems follows the paradigm of assuming hoovering adversaries. Nonetheless, targeting has been shown to sometimes be much more effective than hoovering. For example, password guessing knowledge about the intended victim has been shown to be more effective than hovering in analyses of real data based on leaked datasets of passwords, and typically much more than twice as effective for security-savvy users [10]. And, NIST authentication guidelines, which had been created in consideration of hovering strategies, were quickly modified in light of these analyses.”